

TRƯỜNG ĐẠI HỌC XÂY DỰNG
KHOA CÔNG NGHỆ THÔNG TIN



CHUYÊN ĐỀ TỔNG HỢP

NGÀNH: CÔNG NGHỆ THÔNG TIN

**XÂY DỰNG HỆ THỐNG PHÁT HIỆN BẤT
THƯỜNG VÀ PHÁT HIỆN SỰ CỐ AN NINH
MẠNG**

ĐOÀN TRUNG HIỆU

HÀ NỘI – 2026

TRƯỜNG ĐẠI HỌC XÂY DỰNG
KHOA CÔNG NGHỆ THÔNG TIN
—o0o—



CHUYÊN ĐỀ TỔNG HỢP

NGÀNH: CÔNG NGHỆ THÔNG TIN

**XÂY DỰNG HỆ THỐNG PHÁT HIỆN BẤT
THƯỜNG VÀ PHÁT HIỆN SỰ CỐ AN NINH
MẠNG**

ĐOÀN TRUNG HIẾU

GIÁO VIÊN HƯỚNG DẪN : ThS. NGUYỄN VIỆT NHẬT

HÀ NỘI – 2026

Mục lục

1	Tổng quan về an ninh mạng và các công nghệ giám sát	7
1.1	Tổng quan về an ninh mạng trong doanh nghiệp SME	7
1.2	Các giải pháp giám sát mạng và IDS/Firewall	7
1.2.1	Tường lửa nguồn mở PfSense	7
1.2.2	Hệ thống phát hiện xâm nhập Suricata	8
1.3	Hệ thống thu thập log tập trung	8
1.4	Ứng dụng AI trong phát hiện bất thường	8
2	Thiết kế và triển khai hệ thống phát hiện sự cố	10
2.1	Phân tích yêu cầu và kiến trúc hệ thống đề xuất	10
2.2	Xây dựng hạ tầng mạng ảo hóa và quy hoạch địa chỉ IP	10
2.3	Triển khai Tường lửa PfSense và IDS Suricata	11
2.4	Cấu hình Wazuh Server và Agent trên các máy đích	11
2.4.1	Triển khai Wazuh Server	11
2.4.2	Cài đặt Wazuh Agent trên các máy đích	12
2.5	Thiết lập Decoder, Rules tùy chỉnh và Custom Dashboard	12
2.5.1	Thiết lập Decoder và Rules cho tường lửa PfSense	12
2.5.2	Trực quan hóa dữ liệu thời gian thực với Custom Dashboard	13
2.6	Kịch bản tấn công mô phỏng và sinh dữ liệu mạng	13
3	Tích hợp AI phân tích sự cố, cơ chế cảnh báo tự động và đánh giá hệ thống	15
3.1	Cơ chế tích hợp AI vào hệ thống SIEM Wazuh	15
3.2	Quy trình xử lý và phân tích sự kiện thông minh	15
3.3	Thiết lập hạ tầng và phân ngưỡng kích hoạt cảnh báo	16
3.4	Kịch bản mô phỏng tấn công thực tế	16
3.5	Đánh giá cơ chế cảnh báo thời gian thực qua Telegram	16

Lời cam đoan.

Em xin cam đoan đề tài "XÂY DỰNG HỆ THỐNG PHÁT HIỆN BẤT THƯỜNG VÀ PHÁT HIỆN SỰ CỐ AN NINH MẠNG" là công trình nghiên cứu của bản thân dưới sự hướng dẫn của thầy Nguyễn Việt Nhật. Nội dung đề tài là do em tự thực hiện, không sao chép, vay mượn từ các công trình khoa học của người khác. Mọi tài liệu tham khảo trong đề tài này đều đã được trích dẫn và ghi chú nguồn gốc đầy đủ, chính xác.

Hà Nội, ngày ... tháng ... năm 2026

Sinh viên thực hiện

Đoàn Trung Hiếu

Lời cảm ơn

Trước hết, em xin gửi lời cảm ơn chân thành tới các thầy cô giáo khoa Công nghệ thông tin - Trường Đại học Xây dựng đã tận tình giảng dạy và trang bị cho em những kiến thức chuyên môn quý giá trong suốt quá trình học tập tại trường.

Đặc biệt, em xin gửi lời cảm ơn sâu sắc nhất tới thầy Nguyễn Việt Nhật đã tận tâm hướng dẫn, định hướng và giúp đỡ em trong suốt thời gian thực hiện đề tài này.

Mặc dù đã có nhiều cố gắng để hoàn thiện đề tài, song do kiến thức và kinh nghiệm còn hạn chế nên khó tránh khỏi những thiếu sót. Em rất mong nhận được sự đóng góp ý kiến của quý thầy cô để đề tài được hoàn thiện hơn.

Em xin chân thành cảm ơn!

Hà Nội, ngày ... tháng ... năm 2026
Sinh viên thực hiện

Đoàn Trung Hiếu

Danh mục từ viết tắt, thuật ngữ

STT	Từ viết tắt	Giải nghĩa
1	AI	Trí tuệ nhân tạo
2	FIM	Giám sát tính toàn vẹn tệp tin
3	IDS	Hệ thống phát hiện xâm nhập
4	IPS	Hệ thống ngăn chặn xâm nhập
5	LAN	Mạng cục bộ
6	SCA	Đánh giá cấu hình bảo mật
7	SIEM	Quản lý thông tin và sự kiện bảo mật
8	SME	Doanh nghiệp vừa và nhỏ
9	TLS	Bảo mật tầng truyền tải
10	VM	Máy ảo
11	WAN	Mạng diện rộng

Mở đầu

1. Lý do chọn đề tài:

Trong kỷ nguyên chuyển đổi số hiện nay, hệ thống mạng đóng vai trò là "xương sống" cho mọi hoạt động của doanh nghiệp. Tuy nhiên, các cuộc tấn công mạng ngày càng trở nên tinh vi và phức tạp với quy mô lớn, nhắm vào các lỗ hổng của hệ thống và các hành vi của người dùng, đặc biệt là tại các doanh nghiệp vừa và nhỏ – nơi thường có những hạn chế về ngân sách và nhân sự chuyên phụ trách an ninh mạng.

Các giải pháp truyền thống như Firewall hay IDS thông thường đôi khi trở nên quá tải hoặc gây ra nhiều cảnh báo giả trước các tấn công Zero-day hiện đại. Xuất phát từ nhu cầu thực tế là xây dựng một hệ thống giám sát tự động, có khả năng phát hiện sớm và phản ứng kịp thời và nhanh chóng, em đã chọn đề tài: "Xây dựng hệ thống phát hiện bất thường và phát hiện sự cố an ninh mạng" làm đề tài, nhằm ứng dụng các công nghệ như Wazuh, PfSense, Suricata kết hợp với AI để nâng cao khả năng bảo mật cho hệ thống mạng.

2. Mục tiêu đề tài

Đề tài hướng tới việc hoàn thiện các mục tiêu chính sau:

- Xây dựng hạ tầng: Triển khai môi trường mạng Lab thực tế sử dụng VMware, bao gồm các hệ điều hành phổ biến (Windows, Ubuntu) và các thiết bị mạng giả lập.
- Giám sát tập trung: Thiết lập giải pháp giám sát an ninh mạng toàn diện bằng cách tích hợp PfSense, Suricata và Wazuh để thu thập log tập trung.
- Phân tích thông minh và Cảnh báo tự động: Tích hợp trí tuệ nhân tạo trực tiếp vào hệ thống SIEM Wazuh để tự động phân tích sâu ngữ cảnh sự cố và gửi cảnh báo thông minh, trực quan tới quản trị viên qua nền tảng Telegram.
- Trực quan hóa: Cung cấp giao diện Dashboard chuyên biệt để theo dõi trạng thái an ninh mạng theo thời gian thực.

3. Phạm vi đề tài

Đề tài tập trung vào các phạm vi sau:

- Phạm vi hệ thống: Giới hạn trong môi trường mạng giả lập trên VMware, mô phỏng các phân đoạn mạng LAN và DMZ.
- Phạm vi công nghệ: Tập trung vào việc cấu hình hệ thống quản trị sự kiện SIEM (Wazuh), tường lửa mã nguồn mở (PfSense) và các thuật toán phân loại dữ liệu (Isolation Forest/Random Forest).
- Phạm vi dữ liệu: Phân tích chủ yếu trên dữ liệu log được kết xuất từ các tiến trình hệ thống và lưu lượng mạng của hệ thống Lab đã được thiết lập.

Chương 1: Tổng quan về an ninh mạng và các công nghệ giám sát

1.1 Tổng quan về an ninh mạng trong doanh nghiệp SME

Trong bối cảnh chuyển đổi số diễn ra mạnh mẽ, các doanh nghiệp vừa và nhỏ đang ngày càng phụ thuộc nhiều hơn vào hệ thống công nghệ thông tin. Tuy nhiên, sự phụ thuộc này cũng đi kèm với các rủi ro an ninh mạng gia tăng. Các cuộc tấn công như mã độc tổng tiền, lừa đảo, và tấn công từ chối dịch vụ không chỉ nhắm vào các tập đoàn lớn mà còn chuyển hướng sang các doanh nghiệp SME.

Nguyên nhân chính là do các doanh nghiệp SME thường gặp nhiều hạn chế về nguồn lực: ngân sách đầu tư cho bảo mật hạn hẹp, thiếu hụt đội ngũ nhân sự chuyên trách an toàn thông tin và hệ thống phòng thủ chưa được thiết lập bài bản. Việc phụ thuộc vào các thiết bị mạng cơ bản như router tích hợp sẵn của nhà mạng hoặc các phần mềm diệt virus thông thường không đủ để ngăn chặn các kỹ thuật tấn công tinh vi (Zero-day). Do đó, nhu cầu cấp thiết đặt ra cho các doanh nghiệp SME là tìm kiếm và triển khai các giải pháp bảo mật mã nguồn mở, chi phí thấp nhưng vẫn đảm bảo khả năng giám sát toàn diện và phản ứng nhanh trước các sự cố.

1.2 Các giải pháp giám sát mạng và IDS/Firewall

Để xây dựng một vành đai bảo mật vững chắc cho mạng nội bộ, Tường lửa (Firewall) và Hệ thống phát hiện xâm nhập (IDS) là hai thành phần không thể thiếu.

1.2.1 Tường lửa nguồn mở PfSense

PfSense là một hệ điều hành tường lửa và định tuyến mạng mã nguồn mở dựa trên nền tảng FreeBSD. Với lợi thế miễn phí nhưng sở hữu các tính năng mạnh mẽ không thua kém các giải pháp thương mại, PfSense là lựa chọn lý tưởng cho các doanh nghiệp SME. PfSense cung cấp khả năng định tuyến trạng thái, hỗ trợ cấu hình VLAN linh hoạt, thiết lập mạng riêng ảo (IPsec, OpenVPN), và lọc luồng dữ liệu truy cập từ bên ngoài vào mạng nội bộ.

1.2.2 Hệ thống phát hiện xâm nhập Suricata

Suricata là một công cụ phân tích an ninh mạng, phát hiện và ngăn chặn xâm nhập (IDS/IPS) hiệu năng cao, hoạt động dựa trên tập luật. Khác với các hệ thống cũ, Suricata hỗ trợ xử lý đa luồng, giúp tăng tốc độ phân tích các gói tin trên mạng có băng thông lớn. Khi được tích hợp trên tường lửa PfSense, Suricata đóng vai trò như một bộ lọc thông minh, có khả năng đi sâu vào nội dung gói tin để nhận diện các dấu hiệu tấn công đã biết như quét cổng, dò mật khẩu, hay kết nối đến máy chủ điều khiển mã độc (C&C Server).

1.3 Hệ thống thu thập log tập trung

Khi hệ thống mạng ngày càng mở rộng, số lượng cảnh báo từ các thiết bị tường lửa, máy chủ và máy khách tăng lên theo cấp số nhân. Việc quản trị viên phải kiểm tra nhật ký trên từng thiết bị là điều không khả thi. Giải pháp SIEM ra đời để giải quyết vấn đề này.

Trong đề tài này, giải pháp Wazuh được lựa chọn để triển khai. Wazuh là một nền tảng SIEM và XDR mã nguồn mở mạnh mẽ. Kiến trúc của Wazuh bao gồm hai thành phần chính:

- Wazuh Agent: Được cài đặt trên các máy trạm (Windows, Ubuntu) để giám sát các thay đổi về tệp tin, quét lỗ hổng bảo mật và thu thập log hệ thống.
- Wazuh Manager & Indexer: Máy chủ trung tâm làm nhiệm vụ thu nhận log từ các Agent và các thiết bị ngoại vi (như PfSense), sau đó đối chiếu với các tập luật và cảnh báo để phân tích tương quan sự kiện, từ đó hiển thị lên bảng điều khiển Dashboard.

Nhờ Wazuh, quản trị viên có một cái nhìn toàn cảnh về trạng thái an ninh của toàn bộ hệ thống mạng.

1.4 Ứng dụng AI trong phát hiện bất thường

Mặc dù Suricata và Wazuh hoạt động rất hiệu quả, nhưng cả hai đều phụ thuộc phần lớn vào các "chữ ký" hoặc "tập luật" đã được định nghĩa từ trước. Điểm yếu của phương pháp này là tỷ lệ cảnh báo giả cao và không thể phát hiện các loại hình tấn công mới chưa từng xuất hiện.

Trí tuệ nhân tạo và học máy giải quyết bài toán này bằng cách chuyển đổi sang phương pháp tiếp cận "dựa trên hành vi". Cụ thể, các thuật toán học máy có khả năng:

- Học hỏi tự động: Hệ thống phân tích lượng lớn dữ liệu mạng bình thường để xây dựng một "đường cơ sở" tiêu chuẩn.
- Phát hiện bất thường: Trong quá trình vận hành, bất kỳ lưu lượng hoặc hành vi nào sai lệch đáng kể so với đường cơ sở (ví dụ: lưu lượng tải lên đột ngột lớn, hoặc số lượng truy cập vào giờ khuya tăng vọt) đều bị phân loại là bất thường thông qua các mô hình như Isolation Forest hay Random Forest.

Việc tích hợp AI vào hệ thống giám sát giúp tự động hóa quy trình phân tích, giảm tải khối lượng công việc cho quản trị viên và tăng cường khả năng phát hiện sớm các mối đe dọa.

Chương 2: Thiết kế và triển khai hệ thống phát hiện sự cố

2.1 Phân tích yêu cầu và kiến trúc hệ thống đề xuất

Để hệ thống bám sát thực tế doanh nghiệp, kiến trúc được thiết kế theo một luồng khép kín, đi từ khâu thu thập dữ liệu hạ tầng đến phân tích tự động. Hệ thống thực nghiệm được chia thành ba nhóm thành phần cốt lõi:

- Cổng bảo mật: Sử dụng PfSense làm tường lửa kiểm soát lưu lượng ra vào, tích hợp song song IDS Suricata để bắt các dấu hiệu bất thường ở lớp mạng.
- Máy đích: Bao gồm các máy trạm và máy chủ nội bộ giả lập môi trường người dùng cuối.
- Quản trị tập trung: Nền tảng Wazuh Server đóng vai trò thu thập, phân tích log từ tường lửa và các tác nhân trên máy đích.

2.2 Xây dựng hạ tầng mạng ảo hóa và quy hoạch địa chỉ IP

Môi trường thực nghiệm được triển khai hoàn toàn trên nền tảng ảo hóa VMware. Hạ tầng mạng được chia thành hai phân đoạn chính để đảm bảo tính cô lập và định tuyến rõ ràng:

- Mạng giao tiếp bên ngoài: Sử dụng giao diện mạng ảo VMnet8 cấu hình ở chế độ NAT với dải mạng 192.168.209.X.
- Mạng nội bộ: Sử dụng giao diện mạng ảo VMnet2 cấu hình ở chế độ Host-only với dải mạng 192.168.80.X.

Các máy ảo được quy hoạch địa chỉ IP chi tiết như sau:

- PfSense-Firewall: Được trang bị hai card mạng. WAN được cấp phát IP 192.168.209.128/24, và LAN được gán IP 192.168.80.1/24.
- WinServer2025-Target: Đóng vai trò máy chủ dịch vụ với card mạng Ethernet mang địa chỉ IP 192.168.80.10.
- Win10-Target: Đóng vai trò máy trạm người dùng với card mạng Ethernet mang địa chỉ IP 192.168.80.11.

2.3 Triển khai Tường lửa PfSense và IDS Suricata

Máy ảo PfSense sau khi cài đặt thành công đã thực hiện tốt vai trò định tuyến lưu lượng giữa mạng VMnet8 và VMnet2. Để nâng cao khả năng giám sát mạng lưới dịch vụ Suricata được tích hợp trực tiếp trên PfSense.

Quá trình cấu hình Suricata đã được tối ưu hóa để có khả năng bắt chính xác các dấu hiệu của ba kiểu tấn công phổ biến:

- Quét mạng bằng công cụ Nmap.
- Quét web bằng công cụ Nikto.
- Quét lỗ hổng hệ thống.

2.4 Cấu hình Wazuh Server và Agent trên các máy đích

2.4.1 Triển khai Wazuh Server

Trung tâm giám sát an ninh mạng của hệ thống được xây dựng dựa trên nền tảng Wazuh, đặt trên máy ảo Ubuntu-Wazuh-Server. Nhằm tối ưu hóa tài nguyên phần cứng và linh hoạt trong quá trình quản trị, hệ thống Wazuh được triển khai theo mô hình container hóa (sử dụng Docker). Kiến trúc triển khai bao gồm ba thành phần dịch vụ cốt lõi hoạt động đồng bộ:

- Wazuh Manager: Đảm nhiệm vai trò trung tâm tiếp nhận, phân tích dữ liệu log từ các thiết bị ngoại vi, đối chiếu với tập luật để phát hiện bất thường và phát hành cảnh báo.
- Wazuh Indexer: Đóng vai trò là cơ sở dữ liệu phân tán có khả năng lập chỉ mục văn bản toàn phần, giúp lưu trữ khối lượng lớn log sự kiện một cách an toàn và cho phép truy xuất với tốc độ cao.
- Wazuh Dashboard: Giao diện người dùng trực quan, cung cấp các biểu đồ thống kê và báo cáo trạng thái an ninh theo thời gian thực.

Quá trình cấu hình, liên kết mạng giữa các container đã hoàn tất thành công. Quản trị viên hiện có thể truy cập ổn định vào giao diện giám sát thông qua giao thức HTTPS bảo mật từ trình duyệt web, đồng thời máy chủ đã cấu hình mở các cổng dịch vụ chuẩn (như 1514/TCP) để sẵn sàng tiếp nhận luồng dữ liệu mã hóa từ PfSense và các Agent.

2.4.2 Cài đặt Wazuh Agent trên các máy đích

Để hệ thống SIEM có cái nhìn sâu sát vào hệ điều hành và các tiến trình đang thực thi, phần mềm Wazuh Agent đã được cài đặt trực tiếp lên các máy ảo đích, bao gồm WinServer2025-Target (IP: 192.168.80.10) và Win10-Target (IP: 192.168.80.11).

Agent hoạt động như một tiến trình ngầm tiêu thụ rất ít tài nguyên, nhưng cung cấp các tính năng giám sát toàn diện ở cấp độ máy chủ:

- Giám sát tính toàn vẹn của tệp: Tự động theo dõi, phát hiện và cảnh báo tức thời khi có sự thay đổi (sửa, xóa, tạo mới) trái phép đối với các tệp cấu hình hệ thống hoặc thư mục nhạy cảm.
- Đánh giá cấu hình bảo mật: Quét hệ điều hành và so sánh với các tiêu chuẩn an toàn thông tin (như CIS Benchmarks) nhằm phát hiện sớm các lỗ hổng hoặc cấu hình yếu kém.
- Thu thập nhật ký sự kiện: Liên tục đọc các luồng sự kiện từ Windows Event Log và chuyển tiếp về trung tâm.

Quy trình đăng ký đã được thực thi bằng cách khai báo địa chỉ IP của Ubuntu-Wazuh-Server trên từng Agent. Sau khi xác thực thành công, Wazuh Manager cấp phát cho mỗi Agent một khóa bảo mật riêng biệt. Hiện tại, các kênh giao tiếp TLS giữa Agent và Server đã chuyển sang trạng thái Active, đảm bảo toàn bộ dữ liệu log sự kiện được truyền tải về trung tâm phân tích một cách liên tục, nguyên vẹn và chống bị nghe lén trong mạng nội bộ.

2.5 Thiết lập Decoder, Rules tùy chỉnh và Custom Dashboard

2.5.1 Thiết lập Decoder và Rules cho tường lửa PfSense

Để hệ thống Wazuh SIEM có thể đọc hiểu, bóc tách và phân tích các dòng log tường lửa thô từ PfSense, quá trình cấu hình nâng cao đã được triển khai thông qua việc tùy biến các tập tin quy tắc hệ thống. Cụ thể, tập hợp các quy tắc tùy chỉnh được thiết lập nhằm phân loại chi tiết lưu lượng mạng và các cảnh báo từ hệ thống phát hiện xâm nhập Suricata:

- Xử lý luồng log tường lửa cơ bản: Hệ thống định nghĩa các quy tắc để bắt sự kiện từ tiến trình lọc gói tin của PfSense, qua đó phân loại rành mạch giữa các hành động cho phép lưu lượng đi qua và các hành động ngăn chặn truy cập dựa trên các mức độ cảnh báo phù hợp.

- Ảnh xạ cảnh báo từ Suricata IDS: Các quy tắc chuyên biệt được xây dựng để nhận diện tiền tố cảnh báo từ Suricata, đồng thời phân định chi tiết các kịch bản kiểm thử thực tế xuất phát từ hệ thống tấn công mẫu thông qua các mã định danh sự kiện riêng biệt bao gồm: hành vi quét cổng mạng, quét dò lỗ hổng và hành vi quét ứng dụng web.

Thông qua hệ thống cấu hình này, nền tảng SIEM thực hiện đồng thời hai nhiệm vụ cốt lõi:

- Phân tách luồng log mạng: Thiết lập các bộ lọc giúp bóc tách chính xác các bản ghi hành động mạng từ tường lửa pfSense để phục vụ cho công tác theo dõi trạng thái biên mạng.
- Gom nhóm và phân định cảnh báo xâm nhập: Tự động phân loại toàn bộ các luồng cảnh báo từ Suricata thành các nhóm sự kiện độc lập tương ứng với các kịch bản tấn công thực nghiệm, tạo cơ sở dữ liệu đầu vào chuẩn hóa cho các tầng phân tích thông minh tiếp theo.

2.5.2 Trực quan hóa dữ liệu thời gian thực với Custom Dashboard

Nhằm mục đích theo dõi trực quan các luồng sự kiện bảo mật và đánh giá lưu lượng mạng trong mô hình doanh nghiệp vừa và nhỏ, hệ thống đã được xây dựng các Bảng điều khiển tùy chỉnh chuyên biệt ngay trên giao diện Wazuh. Các số liệu thống kê được thể hiện sinh động thông qua sự kết hợp chặt chẽ của các thành phần:

- Biểu đồ tròn/vành khăn: Thống kê tỷ trọng phân phối các loại hình tấn công và cảnh báo ghi nhận được từ tường lửa.
- Biểu đồ vùng: Theo dõi xu hướng biến động lưu lượng sự kiện theo trục thời gian thực, giúp nhận diện chính xác các thời điểm diễn ra chiến dịch tấn công mô phỏng từ bên ngoài.
- Bảng dữ liệu chi tiết: Liệt kê minh bạch các thông số cốt lõi của sự kiện bảo mật bao gồm thời gian xảy ra, mã định danh luật, tên mô tả cảnh báo cùng địa chỉ IP nguồn và đích phục vụ công tác trích xuất minh chứng thực nghiệm.

2.6 Kịch bản tấn công mô phỏng và sinh dữ liệu mạng

Nhằm đánh giá hiệu năng của kiến trúc hạ tầng đã thiết lập và thu thập tập dữ liệu thực tế phục vụ cho giai đoạn huấn luyện mô hình học máy kế tiếp, một máy tấn công sử dụng hệ điều hành Kali Linux đã được đưa vào vận hành thử nghiệm trong mô hình mạng.

Các kịch bản tấn công mô phỏng thực tế đã được triển khai hướng trực tiếp đến các máy chủ mục tiêu, bao gồm:

- Quét cổng mạng: Sử dụng công cụ Nmap với các kỹ thuật quét TCP SYN nhằm kiểm tra trạng thái cổng và diện mạo dịch vụ mạng.
- Quét lỗ hổng hệ thống: Thực thi các tập lệnh dò quét lỗ hổng nhằm tạo ra các mẫu lưu lượng phân tích chuyên sâu tại tầng mạng.
- Quét ứng dụng web: Sử dụng công cụ Nikto nhắm vào dịch vụ Web trên máy chủ mục tiêu (IIS trên Windows Server 2025) nhằm tạo ra các chuỗi truy vấn kiểm tra ứng dụng web.

Thông qua các kịch bản này, dòng lưu lượng mạng đi qua tường lửa PfSense sẽ bị Suricata IDS bắt giữ, đối chiếu với các quy tắc tùy chỉnh và ghi nhận thành các sự kiện cảnh báo tập trung tại hệ thống Wazuh SIEM. Toàn bộ dữ liệu sự kiện được trích xuất (lưu trữ dưới dạng JSON) sẽ tạo thành cơ sở dữ liệu quan trọng để tiến hành các bước làm sạch và trích xuất đặc trưng phục vụ cho việc xây dựng mô hình AI phát hiện bất thường ở giai đoạn sau.

Chương 3: Tích hợp AI phân tích sự cố, cơ chế cảnh báo tự động và đánh giá hệ thống

3.1 Cơ chế tích hợp AI vào hệ thống SIEM Wazuh

Trong các kiến trúc giám sát an ninh mạng truyền thống, hệ thống SIEM chủ yếu phát hiện sự kiện dựa trên hệ thống tập luật tĩnh. Mặc dù phương pháp này hiệu quả đối với các mẫu tấn công đã biết, nhưng nó gặp hạn chế khi phân tích sâu bản chất ngữ cảnh của các hành vi phức tạp hoặc các biến thể tấn công mới.

Để khắc phục nhược điểm này, đề tài này sử dụng phương pháp tích hợp AI trực tiếp vào luồng xử lý sự kiện của Wazuh Manager thông qua cơ chế tích hợp thông minh ('integrator'). Thay vì trích xuất dữ liệu để huấn luyện mô hình học máy ngoại tuyến phức tạp, hệ thống sử dụng các giao diện lập trình ứng dụng trí tuệ nhân tạo tiên tiến nhằm tận dụng khả năng xử lý ngôn ngữ tự nhiên và phân tích ngữ cảnh bảo mật theo thời gian thực.

3.2 Quy trình xử lý và phân tích sự kiện thông minh

Quy trình tự động hóa phân tích sự cố được thiết lập khép kín thông qua module trung gian chạy trên nền tảng Python được tích hợp vào hệ thống Wazuh Manager với các bước vận hành cụ thể như sau:

- Tiếp nhận và lọc sự kiện: Khi Wazuh Manager ghi nhận một cảnh báo bảo mật đạt ngưỡng cấu hình cho phép, toàn bộ thông tin chi tiết về sự kiện sẽ được đóng gói dưới định dạng cấu trúc chuẩn (JSON).
- Trích xuất đặc trưng sự kiện: Module trung gian tự động bóc tách các trường thông tin cốt lõi bao gồm: định danh quy tắc, mức độ cảnh báo, mô tả sự kiện, địa chỉ IP nguồn, tên thiết bị đích và toàn bộ nội dung nhật ký thô.
- Phân tích chuyên sâu bằng AI: Dữ liệu sự kiện được chuyển tiếp an toàn thông qua giao thức HTTPS tới mô hình AI trung tâm. Mô hình tiếp nhận, đóng vai trò như một

chuyên gia vận hành trung tâm điều hành an ninh mạng, tiến hành đánh giá mức độ nguy hiểm, xác định tính chất thực sự của cuộc tấn công và tổng hợp các khuyến nghị xử lý kỹ thuật.

3.3 Thiết lập hạ tầng và phân ngưỡng kích hoạt cảnh báo

Để đảm bảo hệ thống vận hành ổn định, tránh tình trạng quá tải tài nguyên mạng hoặc phát sinh chi phí xử lý API không cần thiết, cơ chế kích hoạt AI được tinh chỉnh thông qua tệp cấu hình trung tâm của Wazuh Manager.

- Hệ thống được cấu hình chỉ kích hoạt module phân tích thông minh đối với các sự kiện đạt mức độ nguy hiểm từ cấp độ 7 trở lên, đây là ngưỡng cảnh báo thể hiện các hành vi bất thường hoặc dấu hiệu xâm nhập rõ rệt từ bên ngoài.
- Các luồng thông tin sau khi được mô hình AI phân tích sẽ tự động định dạng theo chuẩn Markdown nhằm đảm bảo tính trực quan, rõ ràng trước khi chuyển đổi sang tầng giao tiếp tiếp theo.

3.4 Kịch bản mô phỏng tấn công thực tế

Nhằm kiểm chứng hiệu năng hoạt động của toàn bộ kiến trúc từ lớp mạng, tường lửa, hệ thống SIEM cho đến module tích hợp trí tuệ nhân tạo và cảnh báo, các kịch bản kiểm thử thực tế đã được triển khai thông qua máy tấn công giả lập sử dụng hệ điều hành Kali Linux:

- Kịch bản Quét cổng và ánh xạ dịch vụ: Sử dụng công cụ chuyên dụng thực hiện các tiến trình quét TCP SYN nhằm kiểm tra trạng thái phản hồi của tường lửa pfSense và khả năng ghi nhận của Suricata IDS.
- Kịch bản Kiểm thử ứng dụng web: Thực thi các chuỗi truy vấn kiểm tra lỗ hổng và dò quét ứng dụng web nhắm vào máy chủ mục tiêu (Windows Server 2025).
- Kịch bản Kiểm thử ứng dụng web: Sử dụng công cụ Nikto nhắm vào dịch vụ web trên máy chủ mục tiêu nhằm thực hiện các chuỗi truy vấn kiểm tra lỗ hổng cấu hình và tệp tin nhạy cảm, qua đó kiểm chứng khả năng giám sát và sinh cảnh báo của hệ thống.

3.5 Đánh giá cơ chế cảnh báo thời gian thực qua Telegram

Kết quả thực nghiệm ghi nhận sự thành công đồng bộ của toàn bộ hệ thống:

- Ngay khi các kịch bản tấn công được kích hoạt, hệ thống Suricata và Wazuh Agent đã bắt giữ và ghi nhận sự kiện chính xác, đẩy log về Wazuh Manager theo thời gian thực.

- Thông qua module tích hợp, cảnh báo được chuyển hóa và gửi trực tiếp về nền tảng nhắn tin Telegram của quản trị viên với thời gian phản hồi nhanh chóng.
- Nội dung tin nhắn hiển thị trực quan, cung cấp đầy đủ thông tin định danh sự cố (Agent, Rule ID, Level, Mô tả), kèm theo phần phân tích rủi ro chi tiết và các bước hành động khắc phục sự cố do trí tuệ nhân tạo đề xuất. Điều này giúp nâng cao đáng kể tính chủ động và rút ngắn thời gian phản ứng sự cố cho đội ngũ quản trị hệ thống tại các doanh nghiệp.

Kết luận và hướng phát triển

1. Kết luận

Đề tài đã hoàn thành việc xây dựng và triển khai một hệ thống giám sát, phát hiện sự cố an ninh mạng tích hợp mô hình AI cho mô hình doanh nghiệp SME. Các kết quả đạt được bao gồm:

- Xây dựng thành công hạ tầng mạng ảo hóa trên VMware, cấu hình đồng bộ tường lửa pfSense, Suricata và hệ thống SIEM Wazuh.
- Triển khai các kịch bản mô phỏng tấn công thực tế để thu thập log thực tế.
- Ứng dụng mô hình AI nhằm tự động hóa quá trình phát hiện hành vi bất thường, gửi cảnh báo nhanh chóng.

2. Hướng phát triển

Mặc dù đề tài đã hoàn thành các mục tiêu đề ra về việc xây dựng hạ tầng giám sát và tích hợp cảnh báo thông minh qua Telegram, hệ thống vẫn có thể được mở rộng và nâng cao năng lực vận hành trong tương lai theo các hướng sau:

- Tự động hóa hoàn toàn quy trình phản ứng sự cố: Phát triển và mở rộng các kịch bản phản ứng tự động, cho phép hệ thống tự động ra lệnh cho tường lửa pfSense lập tức cô lập các thiết bị nhiễm mã độc hoặc chặn địa chỉ IP nguồn ngay khi nhận được kết quả cảnh báo nghiêm trọng.
- Tối ưu hóa đa kênh cảnh báo: Mở rộng tích hợp hệ thống thông báo sang các nền tảng quản lý và giao tiếp doanh nghiệp khác như Slack, Microsoft Teams hoặc hệ thống nhắn tin nội bộ để đáp ứng nhu cầu của các mô hình tổ chức đa dạng.
- Mở rộng quy mô hạ tầng mạng Lab: Triển khai và kiểm thử mô hình trên môi trường điện toán đám mây thực tế để đánh giá khả năng mở rộng quy mô, tính sẵn sàng cao và hiệu năng xử lý log của toàn bộ hệ thống dưới tải lớn.

Tài liệu tham khảo

- [1] Wazuh Inc., *Integrations - Alert notification with third-party APIs*, Wazuh Documentation, [Online]. Available: <https://documentation.wazuh.com/>
- [2] Wazuh Inc., *Wazuh Documentation - Open Source Security Information and Event Management*, Wazuh Documentation, [Online]. Available: <https://documentation.wazuh.com/>
- [3] Netgate, *pfSense Documentation*, Netgate Developer and Documentation Portal, [Online]. Available: <https://docs.netgate.com/>